

Chelys Security

Autonomous Penetration Testing Platform
Experiment Log — Stage 1 Progress Snapshot

DATE

May 3, 2026

STAGE

Stage 1 — Pre-Revenue

DEADLINE

June 20, 2026

Experiment Log Types:

☒ General progress update with evidence · ☒ AI-enabled product or workflow test · ☒
Prototype or MVP build

1 Venture Overview

One-Line Description: Chelys Security is an AI-powered SaaS platform that autonomously conducts enterprise penetration tests end-to-end — discovering vulnerabilities, exploiting them, generating evidence, and producing compliance-ready reports — at 1/20th the cost of a human pentest engagement.

Problem Being Solved

Enterprise cybersecurity is in a structural crisis. The average penetration test costs \$15,000–\$50,000 per engagement, takes 2–6 weeks to schedule, and produces a static PDF report that is outdated before remediation begins. Meanwhile:

- 60% of breaches exploit vulnerabilities that were known but untested
- Only 1 in 5 small-to-mid-market companies can afford annual pentests
- The cybersecurity labor shortage is projected to reach 3.5 million unfilled roles globally by 2027

No current solution closes all three gaps simultaneously: **cost, speed, and continuous coverage.**

AI-Enabled Solution

Chelys deploys a multi-agent AI swarm — five specialized attack agents orchestrated by a Claude-powered cognitive engine — that autonomously plans, executes, adapts, and reports a full penetration test in hours rather than weeks, at a cost of **\$0.004–\$0.01 per scan.**

2 Where We Are Today (May 2026)

2A. Product Status — MVP In Development

Current State: Core attack modules and commercial infrastructure are complete. Four modules — Cloud Pentest, Kubernetes Escape Testing, CI/CD Integration, and Bug Bounty Mode — are built but require end-to-end validation before being production-ready.

Module	Status	Description
Swarm Orchestrator	✓ Complete	5-agent adaptive attack swarm with Safety Oracle
Curriculum Scheduler	✓ Complete	Dynamically advances scan depth based on live findings
Living Attack Graph	✓ Complete	Real-time visual attack path graph (nodes + edges)
Web Vulnerability Scanning	✓ Complete	Nuclei, SQLMap, FFUF, XSSStrike, Nikto integration
Active Directory Testing	✓ Complete	Kerberoasting, AS-REP roasting, BloodHound path analysis
Lateral Movement Agent	✓ Complete	secretsdump → NTLM hash extraction → Pass-the-Hash pivot (3-hop max)
Credential Cracking (Hashcat)	✓ Complete	GPU wrapper, auto-dispatched from lateral movement agent
GraphQL Security Agent	✓ Complete	Introspection, depth/batching attacks, IDOR, field suggestion leakage
OSINT Module	✓ Complete	Passive recon via Shodan, DNS, certificate transparency
Compliance Engine	✓ Complete	Findings mapped to PCI-DSS, SOC2, HIPAA, NIST, ISO 27001
SIEM Integration	✓ Complete	Auto-push Sigma/KQL detection rules to Elastic/Splunk
Continuous Monitoring	✓ Complete	Scheduled re-scans with delta change detection
CVE / EPSS Enrichment	✓ Complete	NVD + EPSS API; per-finding exploitation probability badge
PDF Report Generation	✓ Complete	Jinja2 templates; white-labeled for MSP resellers
Cloud Pentest (AWS/GCP/Azure)	🔧 In Progress	IAM misconfig, exposed storage, privilege escalation — built, needs validation
Kubernetes Escape Testing	🔧 In Progress	Privileged container escape, docker.sock, anonymous API — built, needs validation
CI/CD Integration	🔧 In Progress	GitHub Action webhook, auto-verify remediation on deploy — built, needs validation

Module	Status	Description
Bug Bounty Mode	 In Progress	Scope enforcement, traffic headers, plan approval flow — built, needs validation

2B. Commercial Readiness — Infrastructure Complete

Feature	Status	Why It Matters
Stripe Billing + Quota Enforcement	 Complete	Revenue collection — willing customers can pay today
TOTP Multi-Factor Authentication	 Complete	Enterprise auth gate; SOC2 requirement
Email-based Password Reset	 Complete	Standard user lifecycle for trial-to-paid conversion
Audit Log (SOC2-compliant)	 Complete	Required for enterprise buyers and compliance auditors
Team Management + RBAC	 Complete	Supports multi-user security teams (admin / member / viewer)
Slack + Email + Webhook Alerts	 Complete	Day-1 pilot customer requirement; wired to live API
Custom Nuclei Template Upload	 Complete	Bug bounty / red team upsell capability
MSP White-label Branding	 Complete	Channel partner / reseller revenue motion
Remediation Tracker (DB-backed)	 Complete	Team accounts — cross-user visibility of assignments

2C. Technology Stack

- **Backend:** Python (FastAPI), PostgreSQL, Redis, Celery async workers
- **AI Engine:** Anthropic Claude API — cognitive planning, adaptive re-targeting, report narrative generation
- **Frontend:** React + TypeScript, shadcn/ui, Tailwind CSS
- **Security Tools Integrated:** Nmap, Nuclei, SQLMap, Metasploit, NetExec, BloodHound, Hashcat, kubectrl, graphw00f, and 12 others
- **Infrastructure:** Docker Compose; designed for cloud deployment (AWS ECS / Railway)

3 Evidence of AI-Enabled Workflow

How the AI Works — Step by Step

When a user creates a penetration test job, the following autonomous pipeline executes without human intervention:

#	Step	AI Role
1	Attack Planning — Claude receives target context and generates a structured attack plan, selecting which agent classes to activate based on detected technology stack	Claude (Cognitive Planner)
2	Parallel Agent Deployment — 5 specialized agents launch simultaneously: ReconAgent, VulnScanAgent, ExploitAgent, LateralMovementAgent, ReportAgent	Swarm Orchestrator
3	Adaptive Escalation — When a critical exploit is confirmed, the Curriculum Scheduler automatically escalates scan depth to POST_EXPLOIT, activating credential extraction and lateral movement	Curriculum Scheduler
4	Safety Enforcement — The Safety Oracle runs before every destructive action, enforcing scope boundaries, hop limits (max 3), and rate limits	Safety Oracle
5	Real-Time Graph Update — The Living Attack Graph updates as the swarm discovers new hosts and relationships, giving users a visual model of the evolving attack surface	Graph Engine
6	Report Generation — Claude synthesizes all findings into a narrative penetration test report with CVSS scores, EPSS exploitation probabilities, compliance mappings, and remediation guidance	Claude (Report Writer)

\$0.01

COST PER SCAN (AI + COMPUTE)

\$25K

AVG. HUMAN PENTEST COST

2,500x

COST REDUCTION VS. HUMAN

4 Market Opportunity

- **Total Addressable Market:** \$10.9B (global penetration testing market, 2025)
- **Serviceable Market (SMB + Mid-Market):** \$3.2B — companies that currently cannot afford traditional pentests
- **Beachhead Segment:** Series A–C SaaS companies, 50–500 employees, with a security engineer but no pentest budget

Competitive Landscape

Platform	Price	Autonomous?	Lateral Movement	EPSS Enrichment
★ Chelys Security	\$299–\$999/mo	✅ Full	✅ PTH Pivot	✅ Yes
Pentera	~\$50K/yr	Partial	Partial	❌
NodeZero (Horizon3.ai)	~\$35K/yr	Partial	✅	❌
Cobalt (human-led)	\$15K/engagement	❌ Human	❌	❌
Burp Suite Pro	\$450/yr	❌ Manual	❌	❌

Key Differentiators

- **Only platform** that auto-cracks extracted NTLM hashes within the same scan session (Hashcat GPU pipeline)
- **Only platform** with native GraphQL attack surface testing (introspection, batching, IDOR)
- **Only platform** with Kubernetes container escape testing as a built-in module
- **EPSS enrichment** shows real-world exploitation probability — more actionable than CVSS alone
- **CI/CD auto-verify** automatically re-checks findings when code deploys — closing the remediation loop competitors ignore

5 Business Model

Plan	Price	Scans/Month	Target Buyer
Starter	\$299/mo	5	Solo security engineer, early-stage startup
Pro	\$999/mo	30 + monitoring	Growing security team, Series B+
Enterprise	Custom	Unlimited	Large org with SOC2/PCI compliance requirements
MSP Reseller	Revenue share	Unlimited	Managed security service providers (white-label)

Unit Economics (Pro Tier)

\$999 MONTHLY REVENUE (PRO)	<\$3 COGS PER 30 SCANS (AI + COMPUTE)	>99% GROSS MARGIN
---------------------------------------	---	--------------------------------

Go-To-Market Strategy

- **Phase 1 (Now):** Direct outreach to security engineers at Series A–B companies via LinkedIn + security conferences (DEF CON, BSides)
- **Phase 2 (Month 3–6):** Partner with 3–5 boutique MSSP firms; they resell under their brand using white-label branding
- **Phase 3 (Month 6–12):** Product Hunt launch + HackerNews; content marketing via free passive recon tool as acquisition funnel

6 What Remains Before First Paying Customer

Remaining Item	Effort	Blocking?
Validate Cloud Pentest, Kubernetes, CI/CD, and Bug Bounty modules end-to-end	1–2 weeks	⚠ Yes — MVP
Configure Stripe live keys + webhook in production environment	2 hours	⚠ Yes — Revenue
Configure SMTP (SendGrid) for password reset + team invite emails	1 hour	⚠ Yes — User Lifecycle
Deploy to cloud (AWS ECS or Railway) with HTTPS and custom domain	1–2 days	⚠ Yes — Demos
Recruit 3 design partners for pilot (zero-cost access for feedback)	Ongoing	⚠ Yes — Validation
Record 3-minute product demo video	4 hours	Marketing
Security hardening review before customer data enters system	1 week	Trust

What is NOT blocking the first customer: The core platform is fully built and locally functional. Billing collection is implemented. Authentication (MFA, password reset, team invites) is live. Web scanning, AD testing, lateral movement, GraphQL, and compliance reporting all generate real results.

7 Hypotheses Being Tested

PRIMARY HYPOTHESIS

Security engineers at growth-stage companies will pay \$299–\$999/month for autonomous pentesting that produces results equivalent to a \$15,000 human engagement, if the output format matches what their auditors already expect.

SECONDARY HYPOTHESIS

MSSPs will white-label and resell Chelys at 3–5x markup to their SMB clients, creating a scalable channel with minimal CAC and no direct sales headcount required.

What Pilot Customers Will Tell Us (June–August 2026)

- Which finding types do customers act on vs. ignore? (informs agent priority and report formatting)
- Does the report format satisfy SOC2 auditors without manual modification?
- What is the actual conversion rate from 14-day free trial to paid subscription?
- Do customers accept AI-generated evidence as equivalent to human-written pentest findings?
- Which compliance framework mapping (PCI-DSS, SOC2, HIPAA) drives the most urgency for upgrade?

8 Milestones & Timeline

	April 2026	Core attack modules complete — web scanning, AD testing, lateral movement, GraphQL agent, EPSS enrichment, full commercial infrastructure (billing, MFA, audit log, team management)
	May 2026	End-to-end validation of remaining modules — Cloud Pentest, Kubernetes escape testing, CI/CD webhook integration, Bug Bounty mode <i>In progress — these modules are built; validation required before customer exposure</i>
	May 20, 2026	Production deployment on AWS/Railway with HTTPS; Stripe live keys enabled
	June 1, 2026	First design partner pilot begins; accept first paid subscription
	June 20, 2026	AI Venture Velocity Challenge — Stage 1 submission deadline
	July 2026	3 paying customers; first MSSP reseller partnership conversation
	September 2026	\$10K MRR target; begin pre-seed fundraising conversations